

DOCUMENTO DE DIVULGACIÓN PÚBLICA

ODRE PQC v0.2.9

Libro blanco técnico público

Edición en español

Edición pública · 2 de septiembre de 2026

Contenido

1. Resumen ejecutivo
2. Propósito y alcance
3. Arquitectura
4. Perfil criptográfico
5. Contrato de seguridad
6. Modelo de amenaza y límites de confianza
7. Verificación y auditoría
8. Resultados multiplataforma
9. Disciplina de release y evidencia
10. Guía de despliegue
11. Límite de divulgación pública
12. Conclusión

Document identity

Product	ODRE PQC
Version	0.2.9
Artifact	odre_pqc-0.2.9-py3-none-any.whl
Wheel SHA-256	A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697
Evidence manifest SHA-256	4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B
Runtime cryptography	OpenSSL 3.5.8 / ML-KEM-768 / ML-DSA-65
Validated platforms	Windows Server 2022 AMD64; Ubuntu 24.04.4 LTS AMD64
Final audit verdict	ODRE_PQC_v0.2.9_FULL_DEVSEC_AUDIT_PASS

1. Resumen ejecutivo

ODRE PQC es un límite de seguridad poscuántica integrado en la aplicación para rutas protegidas del servidor. Reúne gestión del runtime criptográfico, establecimiento autenticado de sesiones, secuenciación estricta, resistencia a replay, protección semántica de solicitudes y respuestas, confianza en artefactos nativos, control del ciclo de vida y aplicación fail-closed detrás de una superficie de integración pequeña.

La versión 0.2.9 es el candidato multiplataforma sellado identificado por el SHA-256 de este documento. El mismo wheel superó una auditoría completa y nueva de seguridad de desarrollo en Windows Server 2022 AMD64 y Ubuntu 24.04.4 LTS AMD64. Dentro del alcance ejecutado no se confirmó ningún hallazgo nuevo de producto Critical, High o Medium.

Este documento presenta evidencia, no seguridad absoluta. PASS solo se aplica al artefacto, plataformas, modelos de amenaza, configuraciones y pruebas indicados. El despliegue en producción sigue siendo una decisión operativa independiente.

2. Propósito y alcance

El producto no sustituye TLS, identidad, autorización, programación segura, parches, endurecimiento del host, copias de seguridad ni monitorización. Añade un límite frente a rutas seleccionadas: el handler de negocio protegido solo se ejecuta después de que el límite PQC acepte la solicitud.

El modelo de integración es intencionalmente simple: inicializar, ejecutar doctor y verify, registrar install(app), iniciar el servidor y comprobar el estado autenticado. Las diferencias del sistema operativo permanecen dentro del adaptador y los paquetes de runtime nativo.

Integration model

1	<code>odre-pqc init</code>
2	<code>odre-pqc doctor</code>
3	<code>odre-pqc verify</code>
4	<code>from odre_pqc import install install(app)</code>
5	<code>server start → odre-pqc status</code>

3. Arquitectura

El límite contiene una capa de integración, controles de admisión y vinculación semántica, handshake y sesión PQC híbridos, estado de replay y secuencia, envelopes protegidos de solicitud y respuesta, controles de confianza nativa por plataforma e informes autenticados de ciclo de vida y estado.

El contrato de wire está versionado como odre-pqc/3. La semántica observada por el handler coincide con la semántica interna autenticada. El estado, headers ordenados, cookies y cuerpo de la respuesta protegida permanecen dentro del frame; el exterior se limita a metadatos de transporte.

La distribución usa un único wheel de Python con bundles de runtime específicos de cada plataforma. El paquete sellado vincula metadata, manifests, archivos nativos y controles de integridad con una identidad exacta de release.

4. Perfil criptográfico

El runtime auditado se identifica como OpenSSL 3.5.8, OpenSSL_version_num 0x30500080. Las pruebas reales de ML-KEM-768, ML-DSA-65 y el handshake híbrido pasaron en ambos sistemas operativos objetivo.

Una ruta protegida no desciende silenciosamente a protección classical-only. Si provider, claves, sesión, estado de replay, confianza nativa o salud del runtime no cumplen el contrato, la ruta queda bloqueada antes de ejecutar el handler de negocio.

5. Contrato de seguridad

El contrato central es fail-closed. Entradas inválidas o ambiguas, violaciones de replay o secuencia, discrepancias de sesión o ruta, estado no autenticado, objetos nativos inseguros, fallos de inicialización y transiciones inseguras no se convierten en ejecución protegida exitosa.

La semántica autenticada de la solicitud es igual a la observada por el handler. La respuesta protegida conserva confidencialidad e integridad. Ejecutables sensibles y bibliotecas nativas se vinculan a objetos confiables. El estado ON se autentica contra una instancia viva y reciente. Los recursos de seguridad sobreviven a toda solicitud admitida.

6. Modelo de amenaza y límites de confianza

La auditoría trató manipulación de red, replay y concurrencia, entradas malformadas y excesivas, confusión semántica, fuga de metadatos de respuesta, estado tras crash y reinicio, sustitución local de archivos, manipulación de enlaces simbólicos o reparse, inyección de dependencias y provider, y carreras del ciclo de vida.

Se supone que el sistema operativo, CPU, runtime de Python y administrador autorizado no están completamente comprometidos. No se afirma defensa contra kernel malicioso, control administrativo ilimitado, extracción física, fallos de lógica de aplicación tras la admisión, denegación de servicio fuera del alcance probado ni futuros avances criptoanalíticos.

7. Verificación y auditoría

Se instaló una copia nueva del wheel sellado con bloqueo por hash. Los SHA-256 de inicio y final fueron idénticos. No se reutilizaron informes anteriores como evidencia PASS y los bytes del producto no cambiaron durante la auditoría.

La revisión estática cubrió 38 archivos Python y 7.160 líneas, metadata, RECORD, soporte de plataforma, ambos manifests nativos y ambos archivos de runtime. RECORD pasó 45/45 y la contaminación fue 0. Las consultas nuevas de advisory cubrieron 19 dependencias Python, con 0 errores y 0 registros de vulnerabilidad devueltos en ese momento.

Se separaron seis problemas del harness de auditoría; no eran defectos del producto. Tras corregirlos se repitieron los gates afectados sin modificar el wheel sellado.

Published audit metrics

Metric	Windows	Ubuntu
Platform verdict	PASS	PASS

Replay-race requests	1,280	2,880
Double handler execution	0	0
Native load attempts	3,000	-
Atomic replacements observed	1,062	-
Junction create/remove cycles	3,000	-
Late-promotion parent swaps	-	600 / 600
Untrusted load / misbinding	0	0
Unresolved Critical / High / Medium	0 / 0 / 0	0 / 0 / 0

8. Resultados multiplataforma

En Windows se verificaron inicialización nueva, bloqueo de segunda inicialización, doctor, verify, status, transición de sesión, replay race, binding de solicitud/respuesta, confianza ACL, autenticación de estado, vida de recursos al apagar, tamper de protocolo, recuperación de crash y estrés de carga nativa.

En Ubuntu se verificaron inicialización nueva, diagnóstico negativo, PQC real, replay race, admission fuzz, entradas anómalas y grandes, formas de HTTP smuggling, secreto de respuesta, WebSocket fail-closed, confianza de objetos nativos, init concurrente, colisión de workers, reinicio normal y forzado y carreras de parent-object.

9. Disciplina de release y evidencia

ODRE PQC usa una identidad de release inmutable. El artefacto auditado se fija por versión y SHA-256. Si cambian los bytes, hacen falta un artefacto y un ciclo de verificación nuevos; no se reedita silenciosamente la misma versión.

La evidencia separa hallazgos de producto, problemas del harness y problemas de entorno. En v0.2.9: hallazgos de producto 0, remediaciones 0, problemas de entorno 0, Critical/High/Medium sin resolver 0. El contacto con la red de producción fue 0 y producción no cambió.

10. Guía de despliegue

El operador debe comprobar el SHA-256 del wheel, usar las bases soportadas de OS y Python, ejecutar init, doctor y verify en un entorno nuevo controlado, registrar install(app), iniciar la aplicación y confirmar el estado autenticado antes de habilitar tráfico protegido.

También hacen falta TLS independiente, autorización, revisión de seguridad de la aplicación, gestión de secretos, parches y hardening, logs, monitorización, backups, plan de rollback y control de cambios. Una auditoría de desarrollo superada no sustituye la evaluación de riesgo de producción.

11. Límite de divulgación pública

Esta edición excluye claves privadas, secretos, topología de producción, datos de clientes, rutas internas exactas, identificadores operativos, scripts de explotación, código completo del harness y detalles que reducirían materialmente el coste de ataque. Incluye arquitectura, contrato, identidad del artefacto, alcance, métricas y límites necesarios para evaluación externa.

12. Conclusión

ODRE PQC v0.2.9 es un límite PQC sellado, multiplataforma e integrado en la aplicación. El wheel exacto superó la auditoría completa indicada en ambos sistemas oficiales. La afirmación más fuerte respaldada por la evidencia es acotada y reproducible: el artefacto cumplió los gates indicados bajo las condiciones indicadas, sin hallazgos de producto Critical, High o Medium confirmados y pendientes.

Artifact verification

SHA-256

A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697

Evidence manifest SHA-256

4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B

Verification command

```
python -m pip hash odre_pqc-0.2.9-py3-none-any.whl
```

Publication note

Prepared from the sealed v0.2.9 full development-security audit record. Public claims are deliberately scoped to the exact artifact and executed evidence. ODRE AI · Korea · 2026